

Security Incident Report

Cloudora Security Operations | Template CLD-IR-TEMPLATE | Complete every section. If a section is empty, write why.

Report ID	CLD-IR-0001
Related ticket	CLD-0001 - Suspicious sign-in activity: daniel.reeve@cloudora.io
Report title	Executive account takeover via password spray, with MFA persistence and BEC staging
Analyst	SOC Analyst, Cloudora engagement (MyFirstHack training)
Date of report (UTC)	2026-08-10
Incident severity	P1 - executive mailbox compromised during an active enterprise deal; fraud staging in place
Status	Contained - eradication verified, monitoring continues
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

An external actor conducted a low-and-slow password-spraying campaign against Cloudora accounts over three nights and successfully compromised the CEO and one additional employee on 10 August. The investigation was triggered by an unusual early-morning sign-in to the CEO account from Lagos, which conflicted with the account's normal London activity and was preceded by failed login attempts. After gaining access, the actor registered a new authenticator device on the CEO account and created an email rule designed to hide finance and invoice messages, creating a risk of business-email-compromise fraud; the second compromised account was used to access SharePoint. The affected accounts were contained, attacker persistence was removed, attacker infrastructure was blocked, and 24 additional accounts that were targeted but not successfully breached were identified for precautionary password resets.

2. Incident timeline

Time (UTC)	Source	Event	Evidence / notes
Aug 08, 00:00–05:00	Sign-in logs	Password spray night 1: 44 failed sign-ins from the three Lagos IPs across approximately 20 accounts.	CloudoraSignIn_CL; ResultType 50126.
Aug 09, 00:00–05:00	Sign-in logs	Password spray night 2: 36 failed sign-ins from the same infrastructure.	CloudoraSignIn_CL; same low-and-slow pattern.
Aug 10, 00:35:48	Sign-in logs	Third spray night begins; failed attempt against the CEO from 102.89.44.17.	CloudoraSignIn_CL.
Aug 10, 03:09:12	Sign-in logs	Failed CEO sign-in from Lagos.	daniel.reeve@cloudora.io; ResultType 50126.
Aug 10, 03:10:41	Sign-in logs	Second failed CEO sign-in from Lagos.	daniel.reeve@cloudora.io; ResultType 50126.
Aug 10, 03:12:05	Sign-in logs	Successful CEO sign-in from Lagos using Windows 10 / Chrome 125.	Initial access; 102.89.44.17; ResultType 0.
Aug 10, 03:14:30	Sign-in logs	CEO mailbox accessed through Outlook Web.	102.89.44.17.
Aug 10, 03:18:44	Audit logs	New authenticator app registered on the CEO account; device named Pixel 6.	Attacker persistence; T1098.005.
Aug 10, 03:26:02	Sign-in logs	CEO session opened Azure Portal.	102.89.44.17.
Aug 10, 03:31:09	Audit logs	Inbox rule RSS Subscriptions created to hide finance/invoice mail.	BEC staging; T1564.008.
Aug 10, 03:44:55	Sign-in logs	Failed sign-in against Priya Nair from Lagos.	priya.nair@cloudora.io; ResultType 50126.
Aug 10, 03:47:18	Sign-in logs	Successful sign-in to Priya Nair's account from Lagos.	Second confirmed compromise; 102.89.45.101.

CLOUDORA B2B HR Software Security Operations (fictional client - MyFirstHack training)			INCIDENT REPORT TEMPLATE CLD-IR-TEMPLATE
Aug 10, 03:52:40	Sign-in logs	Priya Nair session accessed SharePoint Online.	102.89.45.101; successful access.
Aug 10, 08:41:00	Sign-in logs	Daniel Reeve signed in normally from London using macOS/Safari.	203.0.113.11; establishes conflicting same-day activity.
Aug 10, 08:55	Ticket	IT administrator flagged impossible travel and opened CLD-0001.	Detection / investigation start.
Aug 10, ~10:30	Response	Containment and eradication actions were executed on the affected accounts.	Per completed training scenario: accounts contained, attacker MFA/rule removed, attacker IPs blocked.

3. Findings

Finding 1 -The CEO account was compromised by the password-spray actor.

Evidence: The CEO authenticated successfully at 03:12:05 UTC from 102.89.44.17 in Lagos after failed attempts at 03:09:12 and 03:10:41. The device was Windows 10 / Chrome 125, unlike the account's established London activity, and the same account later had a genuine London sign-in at 08:41.

Why it matters: This establishes the Lagos success as unauthorized access rather than ordinary travel or a location-only anomaly.

Finding 2 -Initial access was a three-night password spray.

Evidence: The Lagos infrastructure generated 114 failed sign-ins across 26 distinct accounts: 102.89.44.17 had 48 failures across 23 accounts, 102.89.45.101 had 38 across 20 accounts, and 102.89.44.23 had 28 across 18 accounts. The activity was concentrated overnight with only a small number of attempts per account.

Why it matters: The many-account / few-attempts pattern is consistent with password spraying (T1110.003) and explains how valid credentials were obtained.

Finding 3 -The attacker established MFA persistence on the CEO account.

Evidence: At 03:18:44 UTC, the audit log records successful registration of an authenticator app named Pixel 6 on daniel.reeve@cloudora.io from 102.89.44.17.

Why it matters: The added authentication method could allow the attacker to retain access after a password reset, so credential reset alone was insufficient containment.

Finding 4 -A BEC email-hiding rule was staged on the CEO mailbox.

Evidence: At 03:31:09 UTC, the audit log records creation of the RSS Subscriptions rule: messages from finance@cloudora.io or containing 'invoice' were moved to RSS Feeds and marked read.

Why it matters: The rule would conceal finance conversations and could support invoice-fraud activity. No outbound fraudulent mail was observed in the available logs.

Finding 5 -Priya Nair's account was also compromised.

Evidence: Priya Nair's account received repeated spray attempts on 8–10 August, followed by a successful login at 03:47:18 UTC from 102.89.45.101 and SharePoint Online access at 03:52:40. Her normal baseline is 33 London sign-ins from 203.0.113.10, with no comparable foreign-travel pattern. The available audit log contains no attacker-origin MFA registration or inbox-rule change for this account.

Why it matters: The account is a confirmed second victim. The absence of persistence events in these logs is not proof that no persistence existed elsewhere.

Finding 6 -Omar Farah's Dubai activity is a cleared false positive for compromise.

Evidence: Omar had 12 successful UAE sign-ins across 8–10 August, all during daytime hours, from his usual iOS 17 / Mobile Safari fingerprint, with no failed attempts immediately before those successes. His six Lagos events were failed spray attempts only.

Why it matters: The activity is consistent with legitimate travel. Omar remains a real spray target and therefore belongs in the precautionary-reset group, but there is no evidence in these logs that he was breached.

4. Indicators of compromise (IOCs)

Type	Value	First seen (UTC)	Context
IPv4	102.89.44.17	Aug 08, ~00:00	Lagos spray source; CEO initial access, MFA registration, inbox-rule creation.
IPv4	102.89.44.23	Aug 08, ~00:00	Lagos spray source; 28 failures across 18 accounts.
IPv4	102.89.45.101	Aug 08, ~00:00	Lagos spray source; Priya Nair compromise.
Device fingerprint	Windows 10 / Chrome 125	Aug 08	Attacker fingerprint associated with 102.89.x.x activity.
MFA device	Pixel 6	Aug 10, 03:18:44	Attacker-registered authenticator on CEO account; removed during containment.
Inbox rule	RSS Subscriptions	Aug 10, 03:31:09	Finance/invoice mail-hiding rule on CEO mailbox; deleted during containment.

5. MITRE ATT&CK mapping

Tactic	Technique ID	Technique name	Evidenced by
Credential Access	T1110.003	Brute Force: Password Spraying	Finding 2 -114 failures, 26 targeted accounts, 3 nights, 3 IPs.
Initial Access	T1078	Valid Accounts	Finding 1 and Finding 5 - successful logins using sprayed credentials.
Persistence	T1098.005	Account Manipulation: Device Registration	Finding 3 -attacker authenticator 'Pixel 6'.
Defense Evasion	T1564.008	Hide Artifacts: Email Hiding Rules	Finding 4 -'RSS Subscriptions' inbox rule.

6. Scope

Accounts confirmed compromised (2): daniel.reeve@cloudora.io; priya.nair@cloudora.io.

Accounts targeted but not breached (24): alba.vega@cloudora.io, amelia.frost@cloudora.io, aria.reid@cloudora.io, cole.burke@cloudora.io, dina.said@cloudora.io, emma.hayes@cloudora.io, ethan.wells@cloudora.io, freya.lynn@cloudora.io, gwen.muir@cloudora.io, isla.grant@cloudora.io, joel.kerr@cloudora.io, jude.ross@cloudora.io, kian.patel@cloudora.io, leah.stone@cloudora.io, lena.voss@cloudora.io, liam.doyle@cloudora.io, mira.shah@cloudora.io, nina.cole@cloudora.io, omar.farah@cloudora.io, rhys.owen@cloudora.io, ruth.dean@cloudora.io, ryan.boyd@cloudora.io, seth.lane@cloudora.io, sofia.marino@cloudora.io (all @cloudora.io).

Accounts investigated and cleared (false positives): omar.farah@cloudora.io. Dubai activity is consistent with legitimate travel; Omar was targeted but not breached.

7. Actions taken

Time (UTC)	Action	Performed by	Verified how
Aug 10, 08:55	IT administrator flagged impossible travel and opened CLD-0001.	Cloudora IT	Investigation initiated; source logs reviewed.
Aug 10, ~10:30	Contained both confirmed compromised accounts and	Cloudora Security Operations / IT	Completed scenario records both accounts as contained.

	revoked attacker access.		
Aug 10, ~10:30	Reset credentials and removed the attacker-registered MFA method from the CEO account.	Cloudora Security Operations / IT	Pixel 6 registration no longer present / identified as removed in completed scenario.
Aug 10, ~10:30	Deleted the CEO mailbox's malicious RSS Subscriptions rule.	Cloudora Security Operations / IT	Rule identified as deleted in completed scenario.
Aug 10, ~10:30	Blocked the identified attacker network addresses.	Cloudora Security Operations / IT	Completed scenario records attacker network addresses as blocked.
Post-containment	Flagged 24 spray-targeted but unbreached accounts for precautionary password resets and continued monitoring.	Cloudora Security Operations / IT	Scope reconciled to 26 targeted accounts: 2 breached + 24 targeted-only.

8. Recommendations

Priority / recommendation	Traces to	Rationale
P1 -Enforce phishing-resistant MFA / strong authentication for executives and high-risk users.	Finding 3	Reduce the value of stolen passwords and prevent attacker-added authentication methods from becoming a durable access path.
P1 -Alert on password spraying using distinct-account thresholds per source IP.	Finding 2	Detect the attack during the first spray night instead of after an account takeover.
P1 -Alert on successful sign-in from a spray-associated IP immediately after credential failures.	Findings 1, 2, 5	Convert an attempted spray into a high-confidence account-takeover alert.
P1 -Monitor and restrict risky mailbox-rule creation, especially finance/invoice mail-hiding rules.	Finding 4	Disrupt business-email-compromise staging and invoice-fraud workflows.
P2 -Implement automated session revocation and credential reset playbooks for identity compromise.	Findings 1, 3, 5	Ensure password reset is paired with session and authentication-method cleanup.
P2 -Maintain baseline-aware impossible-travel and new-device detections.	Findings 1 and 6	Combine location, device, time, and prior behavior so legitimate travel is not treated as compromise.

9. Lessons learned

- What worked: correlating sign-in failures, successful authentication, application access, and audit events produced a coherent end-to-end attack timeline.
- What was slow/missing: the scenario shows the incident was visible in logs on 8 August, but the executive account was not identified as compromised until 10 August; the detection gap was therefore earlier than the takeover.
- Scope discipline: checking every successful sign-in from the spray infrastructure identified a second victim and prevented the investigation from stopping at the CEO.
- False-positive handling: Omar's case demonstrates that location alone is not sufficient; device continuity, time of day, failure history, and behavior over multiple days are stronger evidence.
- Process improvement: deploy the password-spray analytic as a scheduled rule and add a separate high-confidence rule for a spray IP that later succeeds against an account.

Appendix A -Detection engineering task

Night-one password-spray detection rule:

// Scheduled analytics rule -run every 6 hours over the last 6 hours

CloudoraSignIn_CL

| where TimeGenerated > ago(6h)

```
| where ResultType == "50126"
| summarize
    Failures = count(),
    TargetedAccounts = dcount(UserPrincipalName),
    SampleAccounts = make_set(UserPrincipalName, 5)
    by IPAddress, Country
| where TargetedAccounts >= 10
| order by TargetedAccounts desc
```

Appendix B -Near-miss account query

```
let Breached = CloudoraSignIn_CL
| where IPAddress startswith "102.89." and ResultType == "0"
| distinct UserPrincipalName;
CloudoraSignIn_CL
| where IPAddress startswith "102.89." and ResultType == "50126"
| where UserPrincipalName !in (Breached)
| summarize
    Attempts = count(),
    FirstAttempt = min(TimeGenerated),
    LastAttempt = max(TimeGenerated)
    by UserPrincipalName
| order by Attempts desc
```